

Day 9: Incident Reporting & Documentation

SOC Analyst Training Program

1. Why Documentation Is a Core SOC Skill

Finding and stopping a threat is only the technical half of incident response. If the work isn't written down clearly, the value of the investigation mostly evaporates: knowledge that lives only in one analyst's head is lost the moment they go on leave, change teams, or simply forget the details. Documentation is what turns a one-off save into an organizational asset.

Why this matters more than it might seem:

- **Knowledge transfer:** A SOC runs in shifts. Without a clear ticket, the next analyst on shift has to re-investigate from scratch, wasting time during an active incident.
- **Legal and compliance exposure:** Regulations (e.g., HIPAA, PCI-DSS, GDPR breach-notification rules) often require organizations to show evidence of when an incident was detected, how it was handled, and what was done — auditors and lawyers will ask for the ticket, not your memory of it.
- **Career signal:** Analysts who write clearly and precisely are trusted with more responsibility. Technical skill gets you the finding; writing skill gets your finding acted on correctly.

2. What Good Documentation Achieves

- **Legal / compliance / audit record** — a defensible paper trail if the incident is ever reviewed by regulators, auditors, insurers, or law enforcement.
- **Continuity across analysts** — anyone can pick up the case mid-investigation without starting over or duplicating work already done.
- **Post-incident review (PIR) input** — feeds retrospectives / lessons-learned sessions so the same root cause doesn't cause a repeat incident.
- **Institutional knowledge base** — over time, tickets become a searchable history of "how did we handle X last time," speeding up future triage.

3. Structure of a Good Incident Ticket

A well-structured ticket follows a consistent template so any reader — technical or not — can find the information they need without hunting through free-text notes.

Section	What to Include	Why It Matters
Summary	1–2 sentences describing what happened	Gives instant context before diving into detail
Detection Details	How and when the incident was detected (alert name, SIEM rule, etc.)	Shows the trigger and validates detection coverage
Affected Assets	Hostnames, IP addresses, user accounts involved	Scopes the blast radius for containment and reporting
Timeline	Chronological sequence of events with timestamps	Reconstructs exactly what happened and when

Investigation Steps	What you checked and what you found	Makes the analysis reproducible and reviewable
Classification	True Positive / False Positive and severity	Drives prioritization and metrics (e.g., false-positive rate)
Actions Taken	Containment, remediation, response actions	Documents what was actually done, and by whom
Recommendations	Suggested follow-up to prevent recurrence	Turns a single incident into a process improvement

4. Writing a Clear Incident Timeline

The timeline is often the single most-referenced part of a ticket, because it answers the question every stakeholder eventually asks: *"walk me through exactly what happened, in order."* Two rules make a timeline useful instead of just a wall of text:

- **Use exact timestamps**, not vague terms like "a few minutes later" or "shortly after."
- **Use one consistent time zone throughout — normally UTC** — even if the analyst, the log source, and the affected server all sit in different local time zones. Mixing time zones is one of the fastest ways to make a timeline actively misleading during a legal or compliance review.

Example Timeline Entry

```
09:42 UTC - SIEM alert triggered: "Multiple Failed Logins - user: mrivera"
09:45 UTC - Analyst confirmed 62 failed login attempts from IP 198.51.100.23 in 5 minutes
09:47 UTC - Confirmed no successful login occurred; account was not compromised
09:50 UTC - IP address blocked at the firewall; ticket closed as True Positive - Contained
```

Notice the pattern in each line: **[timestamp] – [actor/system] – [specific, measurable action or finding]**. Every entry is falsifiable — someone else could check the SIEM or firewall logs and verify it independently.

5. Communicating with Non-Technical Stakeholders

Not every reader of an incident report is a fellow analyst. Executives, legal counsel, and business unit leads usually care about one thing above all: *business impact* — was data lost, was a system down, does this affect customers or revenue, is there a notification obligation. Translating technical findings into plain, impact-focused language is a distinct skill from the investigation itself.

Technical Version	Executive Version
Detected 4625 brute-force attempts against RDP on Server 07A	A hacker tried but failed to break into a company server through remote access
Malware hash matched a known Emotet variant	A known type of malicious software was found and safely removed before it could

6. Common Documentation Mistakes to Avoid

X Vague descriptions: "Something suspicious happened" tells the next reader nothing actionable. State the specific indicator, host, and behavior observed.

X Missing or inconsistent timestamps / time zones: Breaks the timeline's usefulness for correlation and for legal review.

X Not recording who took which action: Accountability and follow-up both depend on knowing who did what, not just that it was done.

X Excess jargon for non-technical readers: Forces the reader to either misunderstand or come back and ask you to translate — losing time on both sides.

X Leaving ticket status stale after resolution: Breaks metrics (MTTR, open-incident counts) and can cause a resolved issue to be re-escalated.

7. Key Takeaways

- Documentation preserves knowledge, supports compliance, and enables team collaboration — it is a core SOC skill, not paperwork bolted on afterward.
- A good incident ticket always covers: summary, detection details, affected assets, timeline, investigation steps, classification, actions taken, and recommendations.
- Timelines must be precise, chronological, and in one consistent time zone (normally UTC).
- Reports for non-technical audiences should lead with business impact, not technical jargon.